CCNA（200-301 v1.1）　5.0 セキュリティの基礎　#23

レイヤ2と無線のセキュリティ

出題範囲 5.7・5.9・5.10 ― スイッチのポートで守る3つの機能（DHCP スヌーピング・DAI・ポートセキュリティ）と、WLC の画面で WPA2 PSK の無線 LAN を作る手順

各ページの下に、根拠にしたCiscoの資料を書いた（青い文字を押すと開く）

全体像 5.7 Configure and verify Layer 2 security features／5.9・5.10 wireless security

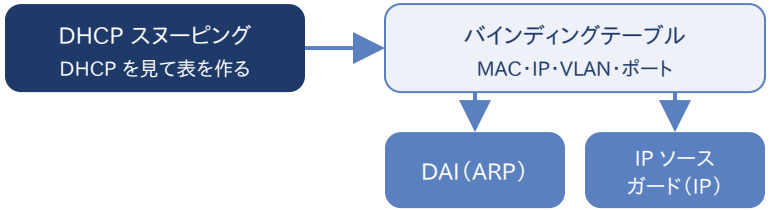
1 DHCP スヌーピング
偽の DHCP サーバーを止める。信頼ポートと信頼しないポート、バインディングテーブル、レート制限

2 DAI と IP ソースガード
ARP スプーフィングを止める。表との照合、ARP ACL、validate、15 pps

3 ポートセキュリティ
ポートにつなげる MAC アドレスを制限。最大数、スティッキー、違反モード、err-disabled

4 WPA2 PSK の WLAN
9800 の GUI で作る手順。Layer 2 Security Mode、AES、AKM、鍵の形式

3つの機能の関係



表を使う2つは DHCP スヌーピングが前提

芯：端末をつなぐポートは**信頼しない**、上流とサーバーのポートだけ**信頼する**。違反やレート超えでポートは **err-disabled** になる。

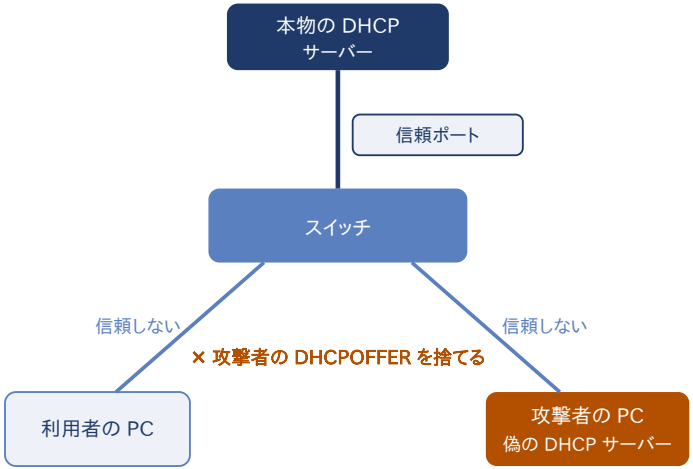
出典：Cisco CCNA Exam v1.1 (200-301) Exam Topics（5.7・5.9・5.10）／Security CG 17.9（9300）「Dynamic ARP Inspection」（Dynamic ARP inspection depends on the entries in the DHCP snooping binding database）

第1章

DHCP スヌーピング

DHCP のやり取りをのぞき見て、偽のサーバーを止め、正しい配布を記録する。

偽の DHCP サーバーと信頼ポート



何も設定しないと、すべてのポートが「信頼しない」

	信頼ポート	信頼しないポート
つなぐもの	本物のサーバー・上流	利用者の端末
既定	—	**すべてのポート**
サーバーのメッセージ	通す	**捨てる**
表への記録	しない	する

偽の DHCP サーバーはうその既定ゲートウェイや DNS を配って通信を横取りする。DHCP スヌーピングは、信頼しないポートに来た **DHCPOFFER・DHCPACK・DHCPNAK** を捨てて防ぐ。

落とし穴：上流（サーバー側）を trust にし忘れると、**本物の応答まで捨てられて**誰もアドレスをもらえない。

出典：IP Addressing Services CG 17.9 (9300)「Configuring DHCP」（DHCP snooping acts like a firewall between untrusted hosts and DHCP servers／By default, the switch considers all interfaces untrusted／all DHCP servers must be connected to the switch through trusted interfaces）／Cisco Doc 217055（This prevents a rogue DHCP server …）

何を捨て、何を記録するか

信頼しないポートで捨てるもの	
パケット	防ぐもの
サーバーが出すメッセージ（OFFER・ACK・NAK・LEASEQUERY）	偽の DHCP サーバー
送信元 MAC ≠ クライアントのハードウェアアドレス（chaddr）	MAC を変えた大量の要求（DoS）
表とちがうポートから来た RELEASE・DECLINE	他人のアドレスを勝手に返す
giaddr が 0.0.0.0 でない／オプション 82 付き	端末がリレーを装う

MAC の照合は既定で有効。オプション 82 は、スイッチが「どのポートから来たか」を書き足す欄。

バインディングテーブル（Cisco の出力例）

```
Switch# show ip dhcp snooping binding
MacAddress          IpAddress  Lease(sec) Type           VLAN Interface
00:A3:D1:44:20:46   10.0.0.3   85556      dhcp-snooping  10   Fo1/0/2
```

入るもの	MAC・IP・リース時間・種類・VLAN・ポート
入らないもの	**信頼ポートの先**の端末
消えるとき	リースが切れたとき、RELEASE を受けたとき
使う機能	**DAI・IP ソースガード**

出典：IP Addressing Services CG 17.9（9300）「Configuring DHCP」（The switch drops a DHCP packet when one of these situations occurs …／The DHCP snooping binding database has the MAC address, the IP address, the lease time, the binding type, the VLAN number, and the interface information … It does not have information regarding hosts interconnected with a trusted interface）／Cisco Doc 217055（出力例／DHCP Snooping removes the entry … when the IP address lease expires or the switch receives a DHCPRELEASE）

設定と確認

Cisco の例（Catalyst 9000）

```
ip dhcp snooping                    ! 全体で有効
ip dhcp snooping vlan 10            ! VLAN ごとに有効
!
interface Fo1/0/10                  ! サーバーへの上流
 switchport mode trunk
 ip dhcp snooping trust
!
interface Fo1/0/2                   ! 利用者（信頼しない）
 switchport access vlan 10
 switchport mode access
 ip dhcp snooping limit rate 10 ! 1秒に10個まで
```

全体（ip dhcp snooping）と VLAN（ip dhcp snooping vlan）の**両方**がないと働かない。

レート制限	DHCP スヌーピング
既定	制限なし
Cisco の勧め	信頼しないポートは **100 pps 以下**
超えたら	ポートが **err-disabled**
自動で戻す	errdisable recovery cause **dhcp-rate-limit**

確かめるコマンド	
show ip dhcp snooping	有効な VLAN、各ポートの信頼とレート
show ip dhcp snooping binding	配られたアドレスの表
show ip dhcp snooping statistics	捨てた数などの統計

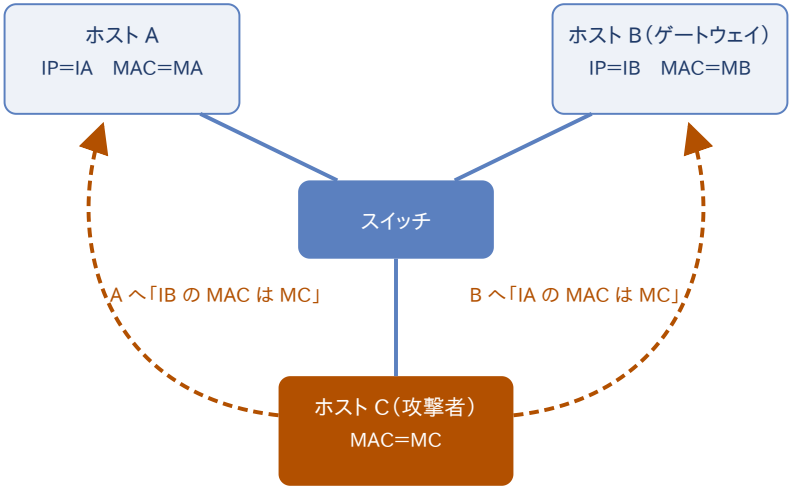
出典：Cisco Doc 217055（設定例）／Catalyst 3560 CG 15.0(1)SE「Configuring DHCP Features」（By default, no rate limit is configured. We recommend an untrusted rate limit of not more than 100 packets per second）／Catalyst 4500 CG IOS XE 3.11.0E「DHCP Snooping」（the switch places the port in the errdisabled state／errdisable recovery cause dhcp-rate-limit）／IP Addressing Services CG 17.9（9300）（Monitoring DHCP Snooping Information）

第2章

DAI と IP ソースガード

バインディングテーブルと比べて、なりすましの ARP と IP を止める。

ARP スプーフィング（ARP キャッシュポイズニング）



うその ARP 応答で、A と B の通信が C を通る（中間者攻撃）

なぜ成り立つか

ARP は**頼んでいない応答（gratuitous ARP）**でも受け取って ARP キャッシュを書き換える。攻撃者がうその応答を流すと、ほかの機器はその IP の宛先 MAC を攻撃者のものと覚えてしまう。

DAI の考え方

1. 信頼しないポートの ARP（要求と応答）を**すべて受け止める**
2. 送信者の IP と MAC の組を**バインディングテーブル**と比べる
3. 合えば転送、合わなければ**捨ててログに残す**

攻撃は同じブロードキャストドメイン（VLAN）の中で起きる。

出典：Security CG 17.9（9300）「Dynamic ARP Inspection」（ARP allows a gratuitous reply from a host even if an ARP request was not received …／Figure 1. ARP Cache Poisoning（Host C … broadcasting forged ARP responses with bindings for a host with an IP address of IA (or IB) and a MAC address of MC）／It intercepts, logs, and discards ARP packets with invalid IP-to-MAC address bindings）。図は Cisco の図をもとに Claude が書き直した

DAI の設定と既定値

```
ip dhcp snooping
ip dhcp snooping vlan 10
ip arp inspection vlan 10                ! VLAN ごとに有効
ip arp inspection validate src-mac dst-mac ip
!
interface g1/0/1                         ! 隣のスイッチ
 ip arp inspection trust
!
arp access-list SRV                      ! 固定 IP の機器
 permit ip host 10.2.2.2 mac host 0018.bad8.3fbd
ip arp inspection filter SRV vlan 10
```

ARP ACL はバインディングテーブルより**先に**調べられる。ACL で deny なら、表に正しい組があっても捨てる。

項目	既定
DAI	どの VLAN でも**無効**
ポートの信頼	すべて**信頼しない**
レート制限	信頼しない **15 pps**／信頼は制限なし。超えたら err-disabled
validate	追加のチェックなし

validate の3つ	
src-mac	ヘッダーの送信元 MAC ＝ ARP の送信者 MAC か
dst-mac	（応答）ヘッダーの宛先 MAC ＝ ARP のターゲット MAC か
ip	0.0.0.0・255.255.255.255・マルチキャストを捨てる

出典：Security CG 17.9（9300）「Dynamic ARP Inspection」（Default Dynamic ARP Inspection Configuration／ip arp inspection validate {[src-mac] [dst-mac] [ip]}／permit ip host 10.2.2.2 mac host 0018.bad8.3fbd／ARP ACLs take precedence over entries in the DHCP snooping binding database）

3つの機能を比べる

	DHCP スヌーピング	DAI	IP ソースガード	ポートセキュリティ
調べるもの	DHCP のメッセージ	ARP の要求と応答	ふつうの IP の送信元	送信元 MAC の数と値
比べる相手	ポートの信頼・chaddr	バインディングテーブル・ARP ACL	バインディングテーブル・静的な登録	セキュア MAC アドレス
防ぐもの	偽の DHCP サーバー	ARP スプーフィング（中間者）	隣の IP のなりすまし	許していない機器の接続
有効にする単位	全体＋VLAN	VLAN	ポート（ip verify source）	ポート
既定のポート	信頼しない	信頼しない	—	無効
止まり方	レート超えで err-disabled	レート超え（15 pps）で err-disabled	合わないパケットを捨てる	違反モードしだい（既定 shutdown）

IP ソースガード：DAI が ARP を見るのに対し、IP ソースガードは**ふつうの IP パケット**を見る。有効にしたポートでは、DHCP スヌーピングが通す DHCP のほかは、**表に載った送信元 IP（mac-check を付ければ MAC も）**だけが通る。

出典：Security CG 17.9（9300）「IP Source Guard」（prevent traffic attacks if a host tries to use the IP address of its neighbor … the switch blocks all IP traffic received on the interface except for DHCP packets allowed by DHCP snooping）／同 CG の Dynamic ARP Inspection・Port Security／IP Addressing Services CG 17.9（9300）。表は Claude がまとめた

第3章

ポートセキュリティ

このポートで使ってよい MAC アドレスを決める。

ポートセキュリティの設定

```
interface g1/0/1
 switchport mode access                  ! 先に固定する
 switchport port-security                ! 有効にする
 switchport port-security maximum 2
 switchport port-security violation restrict
 switchport port-security mac-address sticky
 switchport port-security aging time 120
 switchport port-security aging type inactivity
```

既定	値
ポートセキュリティ	無効
最大数	1
違反モード	shutdown
スティッキー学習・エージング	無効

セキュア MAC アドレスの3種類			
種類	覚え方	running-config	再起動後
静的	手で書く	入る	保存すれば残る
動的	自動	入らない	消える
スティッキー	自動（手でも可）	**入る**	**保存すれば残る**

前提：既定の dynamic auto のポートには設定できない（アクセスかトランクに固定）。EtherChannel のポートでは使えない。

IP 電話の先に PC をつなぐポートは最大数 2（電話1・PC1）。

出典：Security CG 17.9（9300）「Port Security」（Types of Secure MAC Addresses／Default Port Security Configuration／an interface in the default mode (dynamic auto) cannot be configured as a secure port／Port Security is not supported on EtherChanel interfaces／set the maximum allowed secure addresses on the port to two／The sticky secure MAC addresses do not automatically become part of the configuration file）

違反モードと err-disabled

違反になるとき

1. 最大数まで覚えたあと、**知らない MAC** の機器が来た
2. あるセキュアポートで覚えた MAC が、**同じ VLAN の別のセキュアポート**に現れた

モード	知らない送信元	知らせる	カウンター	ポート
protect	捨てる	×	×	動く
restrict	捨てる	syslog・トラップ	○	動く
shutdown	全部止まる	—	○	err-disabled
shutdown vlan	その VLAN が止まる	—	○	VLAN だけ

err-disabled からの戻し方

```
interface g1/0/1
 shutdown
 no shutdown                    ! 手で戻す
!
errdisable recovery cause psecure-violation   ! 自動で戻す
```

原因	自動復旧の cause
ポートセキュリティの違反	psecure-violation
DHCP のレート超え	dhcp-rate-limit

見分け方：気づけないのは **protect**。知らせるがポートを止めないのは **restrict**。止めるのが **shutdown（既定）**。

確かめる：show port-security interface g1/0/1（最大数・今の数・違反の回数・違反モード）

出典：Security CG 17.9（9300）「Port Security」（Security Violations／Security Violation Mode Actions の表／errdisable recovery cause psecure-violation … or … shutdown and no shutdown／Monitoring Port Security）／Catalyst 4500 CG IOS XE 3.11.0E（errdisable recovery cause dhcp-rate-limit）。「知らせる」の列の「—」は、Cisco の表と手順の説明で書き方が分かれているので空けた

第4章

WPA2 PSK の無線 LAN

Catalyst 9800 の GUI で作る（無線のしくみは #10）。

9800 の GUI で WPA2 PSK の WLAN を作る

1. **Configuration > Tags & Profiles > WLANs** で **Add**
2. **General** タブ：Profile Name・SSID・WLAN ID を入れ、Status を有効にする
3. **Security > Layer2** タブ：Layer 2 Security Mode ＝ **WPA + WPA2**、**WPA2 Policy** にチェック、暗号は **AES**
4. 同じタブの認証キーの管理（AKM）：**802.1X を外し、PSK** にチェック。PSK Format（ASCII／Hex）と鍵を入れる
5. **Apply to Device** で反映（端末に出すには、ポリシータグで AP に付ける：#10）

> **落とし穴：**WPA・WPA2 の既定の AKM は **802.1X**。PSK に変え忘れると RADIUS を探しに行き、鍵を入れてもつながらない。

同じ設定を CLI で（Cisco の例をもとに）

```
wlan SHOP 1 SHOP
 no security wpa akm dot1x
 security wpa wpa2
 security wpa wpa2 ciphers aes
 security wpa akm psk
 security wpa psk set-key ascii 0 Cisco123
 no shutdown
```

項目	決まり
鍵（ASCII）	8〜63 文字（% は避ける）
鍵（Hex）	64 けた
SSID	32 文字まで
鍵の使われ方	端末との間の PMK になる

出典：Catalyst 9800 CG 17.9「WLAN Security」（click Security > Layer2. From Layer 2 Security Mode drop-down menu, select WPA + WPA2／By default, both WPA1 and WPA2 use the 802.1X for authenticated key management／This key is used as the Pairwise Master Key (PMK)／WPA preshared keys must contain 8 to 63 ASCII text characters or 64 hexadecimal characters）／同「WLANs」（Configuration > Tags & Profiles > WLANs page, click Add／A valid SSID can be up to 32 characters）／同「WPA3」（no security wpa akm dot1x／security wpa wpa2 ciphers aes／security wpa psk set-key ascii 0 Cisco123）。CLI の並びは Claude が WPA2 PSK だけに組み直した

WPA・WPA2・WPA3 をおさらい くわしくは #10 無線LAN

	暗号化（既定）	個人向け（Personal）	会社向け（Enterprise）	9800 の Layer 2 Security Mode
WPA	TKIP（古い）	PSK	802.1X	WPA + WPA2 の中の WPA Policy
WPA2	**AES-CCMP**	**PSK**	802.1X（RADIUS）	**WPA + WPA2** の中の WPA2 Policy
WPA3	AES（CCMP・GCMP）	**SAE**	802.1X（SHA256 など）	WPA3 か WPA2 + WPA3

WPA2 Personal と Enterprise：Personal（PSK）は全員で同じ鍵を使い、利用者を区別できない。Enterprise（802.1X）は利用者ごとに RADIUS で認証する。会社では Enterprise。

WPA3 の決まり：WPA3 では **PMF（管理フレームの保護）が必須**。WPA2 と WPA3 を同じ WLAN で出す（SAE と PSK を両方）ときは PMF は任意だが、無効にはできない。

出典：Catalyst 9800 CG 17.9「WLAN Security」（WPA1 using TKIP and WPA2 using AES-CCMP … support multiple authentication options including 802.1X, PSK）／同「WPA3」（For WPA3, PMF is mandatory／If both WPA2 and WPA3 are supported (SAE and PSK together), it is optional to configure PMF. However, you cannot disable PMF／Layer 2 Security Mode … WPA2+WPA3 or WPA3）／同「WLANs」（WPA3 + GCMP256 cipher …）

よくあるひっかけ

よくある思い込み	正しくは
DHCP スヌーピングでは端末のポートを trust にする	trust にするのは**サーバー側・上流**。端末は既定の信頼しないまま
ip dhcp snooping だけで働く	**ip dhcp snooping vlan** も要る
DAI は MAC アドレステーブルと比べる	**DHCP スヌーピングのバインディングテーブル**（固定 IP は ARP ACL）
DAI のレート制限の既定は制限なし	信頼しないポートは **15 pps**。信頼ポートが制限なし
ポートセキュリティの違反モードの既定は restrict	既定は **shutdown**（最大数は 1）
protect でも違反カウンターは増える	protect は**何も知らせず、カウンターも増えない**
スティッキーは自動で startup-config に残る	running-config だけ。**保存しないと再起動で消える**
err-disabled は時間がたてば自動で戻る	自動復旧は既定で無効。**shutdown → no shutdown** か errdisable recovery
WPA2 の WLAN は作れば PSK になる	既定の AKM は **802.1X**。PSK に変える

出典：このPDFの各ページの資料

まとめ

DHCP スヌーピング
全体+VLAN で有効。サーバー側だけ trust。信頼しないポートでサーバーのメッセージを捨て、バインディングテーブルを作る。レート超えで err-disabled

DAI と IP ソースガード
表（固定 IP は ARP ACL）と比べてなりすましを捨てる。DAI は VLAN ごと、信頼しないポートは 15 pps

ポートセキュリティ
アクセスかトランクに固定して有効に。既定は最大数 1・shutdown。protect／restrict／shutdown、スティッキー、エージング

WPA2 PSK の WLAN
WLANs > Add → General → Security > Layer2（WPA + WPA2・WPA2 Policy・AES・PSK）→ Apply to Device

確かめるコマンド

```
show ip dhcp snooping
show ip dhcp snooping binding
show ip arp inspection interfaces
show ip arp inspection vlan 10
show port-security interface g1/0/1
show interfaces status
```

次の分野：#24 自動化と SDN で、コントローラーを使ったネットワークと、従来の管理との違いを読む。

出典：このPDFの各ページの資料